

SISTEMA MedIA

Expediente Clínico Electrónico — Distrito de Salud I, Chiapas

DOCUMENTO 6

Descripción de Diagramas del Sistema

Arquitectura · Casos de Uso · Flujos Clínicos · Seguridad

Total de diagramas	6 diagramas con descripción textual detallada
Formato	Descripción textual estructurada (sin código Mermaid)
Ciclo escolar	8° Semestre IDTS — UNACH, Enero–Junio 2026

Diagrama 1 — Arquitectura del Sistema

Este diagrama describe la topología completa de MedIA en producción, mostrando todos los componentes tecnológicos y sus relaciones de comunicación. Se organiza en cinco capas horizontales que representan el recorrido de una petición desde el navegador del usuario hasta la base de datos.

Capa 1 — Usuarios y Dispositivos

Los actores del sistema son seis tipos de usuarios: Médico General, Médico Especialista, Enfermería, Administrador, Auditor de Seguridad y Superadmin. Cada uno accede al sistema desde un navegador web moderno (Chrome, Firefox, Edge) instalado en una computadora de escritorio o laptop en las unidades médicas del Distrito I de Chiapas. No se requiere instalación de cliente.

Capa 2 — Frontend (Azure Static Web Apps)

La interfaz de usuario es una Single Page Application (SPA) construida con React 18 y Vite, desplegada en Azure Static Web Apps. Esta capa incluye los 9 módulos del sistema (Dashboard, Pacientes, Expediente, Consulta, Referencias, Documentos, Auditoría, Administración y Seguridad), el sistema de enrutamiento basado en roles y los componentes de la librería shadcn/ui.

El frontend no almacena datos clínicos permanentemente. Solo gestiona estado local de sesión (JWT en memoria) y cache de catálogos estáticos cacheados en memoria durante la sesión. IndexedDB descartado del MVP (mejora futura). El token JWT tiene vigencia de 30 minutos en producción y no se almacena en localStorage por Requisito Forense 8.

Capa 3 — Azure Front Door + CDN

Actúa como punto único de entrada al sistema. Tiene dos funciones: (a) enrutamiento inteligente de peticiones API hacia el backend más cercano y (b) caché de catálogos estáticos en nodos CDN. Los catálogos CIE-10, municipios y medicamentos tienen un TTL de 24 horas en CDN, reduciendo la latencia en clínicas rurales de Chiapas con ancho de banda limitado.

Front Door valida el certificado TLS y rechaza todo tráfico HTTP plano, garantizando cifrado en tránsito conforme a NOM-024-SSA3-2012.

Capa 4 — Backend (Azure App Service)

La API REST está construida con FastAPI y Python 3.11, desplegada en Azure App Service (plan B1, Linux (Free tier en prueba, B1 para demo final)). Es el núcleo de la lógica de negocio y seguridad del sistema. Sus responsabilidades incluyen:

- Autenticación JWT + TOTP (2FA): valida credenciales, emite tokens con claims de rol y establecimiento

- Middleware de auditoría: registra toda petición en auditoria_accesos ANTES de procesar la lógica de negocio
- Control de acceso granular: aplica las 4 Reglas de Negocio del Reporte Técnico v3
- Generación de SAS tokens efímeros (TTL 15 min) para acceso a documentos en Blob Storage
- Orquestación de firma electrónica: calcula SHA-256 del cuerpo de la nota antes de activar el flag esta_firmada
- Gestión del ciclo de vida de incidentes: CRUD del módulo de seguridad

Capa 5 — Datos y Almacenamiento (Azure)

Esta capa contiene tres servicios de datos:

- Azure Database for PostgreSQL (Flexible Server): base de datos principal con 40 tablas, triggers de auditoría inmutable, soft delete en 7 tablas clínicas y PITR con retención de 14 días.
- Azure Blob Storage: repositorio exclusivo de archivos de origen externo — PDFs de resultados de laboratorio y documentos de tutores. Los documentos generados por el sistema (receta, nota SOAP, solicitud, referencia) se producen on-demand con WeasyPrint y NO se persisten en Blob. Acceso exclusivamente mediante SAS tokens generados por el backend. Nunca expuesto directamente al frontend.
- Azure Key Vault: almacenamiento seguro de todos los secretos del sistema (cadena de conexión BD, SECRET_KEY JWT, credenciales de Blob Storage). El backend lee los secretos en tiempo de arranque mediante Managed Identity, sin credenciales hardcodeadas.

Conexiones del Diagrama

Origen	Destino	Protocolo	Notas
Navegador	Azure Front Door	HTTPS / TLS 1.3	Todo el tráfico
Front Door	Static Web Apps	HTTPS	Peticiones al frontend
Front Door	App Service	HTTPS	Peticiones /api/*
App Service	PostgreSQL	TCP 5432 / SSL	Solo desde VNet privada
App Service	Blob Storage	HTTPS SDK	SAS tokens 15 min
App Service	Key Vault	HTTPS REST	Managed Identity
App Service	Azure Monitor	SDK interno	Logs y métricas

Diagrama 2 — Casos de Uso por Rol

Este diagrama describe las acciones que puede realizar cada uno de los seis roles definidos en MedIA. Se organiza como un diagrama de casos de uso UML donde cada rol (actor) tiene una elipse de casos de uso asociados.

Actor 1 — MEDICO_GENERAL

Rol de primer nivel de atención. Es el actor más activo del sistema. Sus casos de uso principales son:

- Buscar y registrar pacientes nuevos en el sistema
- Consultar el expediente clínico completo de un paciente con encuentro activo
- Registrar signos vitales e iniciar encuentro clínico
- Redactar nota SOAP completa (Subjetivo, Objetivo, Análisis, Plan)
- Seleccionar diagnóstico CIE-10 con autocompletado por código o descripción
- Generar y firmar electrónicamente la nota médica (NOM-151)
- Prescribir medicamentos del Cuadro Básico SSA
- Emitir referencias médicas a otras unidades del Distrito I
- Descargar PDF de nota firmada, receta electrónica y solicitudes de estudio
- Agregar o confirmar alergias del paciente con clasificación por severidad

Actor 2 — MEDICO_ESPECIALISTA

Comparte todos los casos de uso del Médico General con capacidades adicionales:

- Acceder a notas médicas de otros establecimientos del Distrito cuando existe referencia médica activa con estado ACEPTADA o ATENDIDA
- Visualizar solo las especialidades que su establecimiento tiene registradas en establecimientos_especialidades
- Emitir contrarreferencias al establecimiento de origen
- Registrar resultados de estudios de laboratorio vinculados a solicitudes previas

Actor 3 — ENFERMERIA

Rol de soporte clínico. Sus casos de uso son:

- Consultar listado de pacientes en espera de signos vitales (dashboard rol enfermería)
- Registrar signos vitales: tensión arterial, frecuencia cardíaca, temperatura, peso, talla, saturación de oxígeno
- Visualizar alergias del paciente (solo lectura) para alertas de triage
- Consultar expediente del paciente (solo lectura, sin acceso a notas SOAP completas)

Actor 4 — ADMINISTRADOR

Gestión operativa del nodo (establecimiento). Sus casos de uso son:

- CRUD completo de usuarios del sistema dentro de su establecimiento
- Asignar y revocar roles a usuarios
- Configurar especialidades activas del establecimiento
- Visualizar usuarios activos y últimos accesos
- Leer bitácora de auditoría del establecimiento (no puede modificarla)
- Actualizar información del establecimiento (nombre, turno, consultorio)

Actor 5 — AUDITOR_SEGURIDAD

Rol de solo lectura con acceso exclusivo a módulos de auditoría. Sus casos de uso son:

- Visualizar bitácora de accesos filtrada por fecha, usuario, módulo, tipo de evento o nivel de severidad
- Ver lista de incidentes de seguridad activos y resueltos
- Consultar el detalle completo de un incidente: timeline, evidencias, acciones tomadas
- Exportar reportes de auditoría en PDF para autoridades sanitarias
- Ver sesiones activas del sistema (solo lectura, sin poder invalidarlas)

Actor 6 — SUPERADMIN

Acceso total al sistema. Incluye todos los casos de uso anteriores más:

- Ver métricas del sistema en tiempo real: usuarios activos, carga de la BD, errores recientes
- Invalidar sesiones activas de cualquier usuario
- Bloquear y desbloquear cuentas de usuario
- Gestionar el ciclo de vida completo de incidentes (crear, clasificar, contener, erradicar, cerrar)
- Acceder al módulo de seguridad: sesiones activas, tokens inválidos
- Ejecutar invalidación de cache CDN para catálogos actualizados
- Crear establecimientos y jurisdicciones sanitarias

Diagrama 3 — Flujo de Consulta Médica Completa

Este diagrama describe el flujo de negocio más crítico del sistema: una consulta médica completa desde el registro de signos vitales hasta la firma electrónica de la nota SOAP, cumpliendo con NOM-004-SSA3-2012.

PRECONDICIÓN

El médico tiene un encuentro_clinico activo (fecha_cierre = NULL) para el paciente. El paciente ya está registrado en el sistema. El módulo CONSULTA muestra el número de expediente en el TopBar desde el inicio.

Paso	Actor	Acción	Estado resultante
1	Enfermería	Registra signos vitales del paciente (tensión, frecuencia, temperatura, peso, talla, saturación O2)	Paso 1 COMPLETADO — Stepper avanza a Paso 2
2	Sistema	Guarda timestamp exacto (TIMESTAMPTZ con hora:minuto UTC) del registro de signos en signos_vitales.registrado_en	Trazabilidad NOM-004 garantizada
3	Médico	Inicia Paso 2: SOAP — Subjetivo. Redacta motivo de consulta y síntomas referidos por el paciente en texto libre	Paso 2 en progreso
4	Sistema	Guarda timestamp al avanzar desde Paso 2 a Paso 3 (cumplimiento NOTAS_PENDIENTES.md — gap 4)	Timestamps completos en nota SOAP
5	Médico	Paso 3: SOAP — Objetivo. Registra exploración física y hallazgos clínicos	Paso 3 en progreso
6	Médico	Paso 4: SOAP — Análisis/Diagnóstico. Usa autocompletado CIE-10 (código + descripción) para seleccionar diagnóstico principal y hasta 4 diagnósticos secundarios	CIE-10 validado, diagnósticos_encuentro guardados
7	Sistema	Verifica que código CIE-10 existe en cat_cie10 — rechaza códigos no válidos con error de validación	Interoperabilidad semántica NOM-024
8	Médico	Paso 5: SOAP — Plan. Selecciona medicamentos del Cuadro Básico SSA, especifica dosis, vía de administración y duración	Prescripciones registradas en tabla prescripciones
9	Sistema	Valida que id_medicamento exista en cat_medicamentos (FK con ON DELETE RESTRICT)	Integridad referencial garantizada
10	Médico	Paso 6: Firma. Revisa la nota completa. El sistema muestra: número de expediente, CLUES del establecimiento, nombre del médico y cédula	Vista previa de firma — NOM-151

Paso	Actor	Acción	Estado resultante
11	Médico	Confirma la firma electrónica ingresando su contraseña y código TOTP de 6 dígitos	Doble factor de autenticación para acto de firma
12	Sistema	Calcula SHA-256 del contenido completo de la nota SOAP. Activa flag esta_firmada = TRUE. El trigger tr_notes_protection bloquea cualquier modificación posterior	Nota inmutable — NOM-151 cumplida
13	Sistema	Muestra sello visual de firma: Firmado · fecha y hora CST · SHA-256 (primeros 16 chars) · nombre médico · cédula · CLUES	Comunicación de inmutabilidad al médico
14	Sistema	Genera PDF de la nota firmada on-demand con WeasyPrint. No se persiste en Blob Storage. Genera registro en auditoria_accesos con tipo_evento FIRMA_NOTA	Documento firmado disponible para descarga

POSTCONDICIÓN

La nota SOAP queda firmada e inmutable en la BD. El encuentro_clinico.estado = CERRADO. La nota es accesible para descarga PDF. Cualquier corrección posterior requiere una nota_enmienda que referencia la nota original (NOM-004, art. 5.11).

Diagrama 4 — Flujo de Login con 2FA

Este diagrama describe el proceso de autenticación de dos factores (2FA) que cumple NOM-024-SSA3-2012 para sistemas de información en salud. Se usa TOTP (Time-based One-Time Password) con ventana de 30 segundos.

ACTORES DEL FLUJO

Usuario (cualquier rol) y Sistema MedIA (frontend React + backend FastAPI + BD PostgreSQL)

Paso	Actor	Acción	Estado resultante
1	Usuario	Accede a la URL del sistema. El frontend carga la vista de login con campos usuario y contraseña	Pantalla Login visible
2	Usuario	Ingresa nombre de usuario (username) y contraseña en texto plano	Datos capturados en estado local React
3	Frontend	Envía POST /api/auth/login con body { username, password } sobre HTTPS/TLS	Petición en tránsito cifrada
4	Backend	Busca usuario en usuarios_sistema por username. Si no existe, devuelve HTTP 401 genérico ('Credenciales incorrectas') sin revelar si el usuario existe o no	Protección contra enumeración de usuarios
5	Backend	Verifica password contra hash Argon2id almacenado. Si falla, incrementa contador de intentos fallidos. Si supera 5 intentos, bloquea la cuenta y registra BLOQUEO_CUENTA en auditoria_accesos	Protección fuerza bruta
6	Backend	Credenciales correctas: genera un token temporal pre-2FA (fase_autenticacion = PENDIENTE_TOTP) con TTL de 5 minutos	Primera fase completa
7	Frontend	Recibe token pre-2FA y muestra la pantalla de verificación TOTP con 6 campos de un dígito cada uno (diseño OTP pattern del prototipo)	Vista OTP renderizada
8	Usuario	Abre app de autenticador (Google Authenticator, Authy, etc.), lee el código TOTP de 6 dígitos vigente y lo ingresa	Código TOTP ingresado
9	Frontend	Envía POST /api/auth/verify-totp con body { token_preauth, totp_code } sobre HTTPS	Segunda petición de autenticación
10	Backend	Descifra totp_secret_encrypted del usuario (AES-256), genera código TOTP esperado con PyOTP para el timestamp actual. Compara con el código recibido con ventana de ± 1 período (tolerancia de reloj)	Validación TOTP
11	Backend	TOTP válido: genera JWT final con claims { id_usuario, id_rol, id_establecimiento, exp: }	JWT emitido, auditoría registrada

Paso	Actor	Acción	Estado resultante
		now+30min }. Registra LOGIN_EXITOSO en auditoria_accesos con IP, timestamp UTC, módulo_funcion = 'auth.login'	
12	Frontend	Guarda JWT en memoria React (NO en localStorage ni cookies). Redirige al Dashboard según el rol del usuario	Sesión activa iniciada
13	Sistema	TOTP inválido: devuelve HTTP 401, registra INTENTO_TOTP_FALLIDO en auditoria_accesos. Después de 3 intentos TOTP fallidos, invalida el token pre-2FA y requiere reiniciar el proceso	Protección contra ataques TOTP

POSTCONDICIÓN

Usuario autenticado con JWT en memoria. El JWT incluye el rol y el id_establecimiento para que el backend aplique las Reglas de Negocio de acceso. Todas las peticiones posteriores incluyen el header Authorization: Bearer <JWT>.

Diagrama 5 — Flujo de Referencia Médica entre Establecimientos

La referencia médica es el mecanismo normado para transferir la responsabilidad asistencial de un paciente de un establecimiento a otro dentro del Distrito I. Este flujo implementa el Sistema de Referencia y Contrarreferencia (SRC) normado por la Secretaría de Salud y registrado en la tabla `referencias_medicas` del modelo.

ACTORES Y ENTIDADES

Médico emisor (Establecimiento A) · Médico receptor (Establecimiento B) · Tabla `referencias_medicas` · Tabla `auditoria_accesos` · Módulo de Notificaciones

Sub-flujo A — Emisión de la Referencia

Paso	Actor	Acción	Estado resultante
1	Médico (Estab. A)	Desde el encuentro clínico activo, accede al módulo Referencias y selecciona 'Nueva referencia'	Formulario de referencia abierto
2	Médico (Estab. A)	Selecciona: (a) Establecimiento destino del Distrito I, (b) especialidad requerida, (c) nivel de urgencia (URGENTE/PROGRAMADA), (d) motivo clínico y diagnóstico CIE-10 de referencia	Datos de la referencia capturados
3	Sistema	Valida que el establecimiento destino tenga activa la especialidad solicitada en <code>establecimientos_especialidades</code> . Si no, muestra advertencia pero permite continuar	Validación de capacidad instalada
4	Sistema	Crea registro en <code>referencias_medicas</code> con estado = PENDIENTE. Genera folio único de referencia. Registra en <code>auditoria_accesos</code> tipo_evento = EMISION_REFERENCIA	Referencia pendiente creada
5	Sistema	Notifica al establecimiento destino (indicador visual en módulo Referencias, bandeja de recibidas)	Notificación enviada

Sub-flujo B — Aceptación y Atención

Paso	Actor	Acción	Estado resultante
1	Médico (Estab. B)	Accede a la bandeja de referencias recibidas. Ve el folio, diagnóstico CIE-10, urgencia y motivo clínico	Vista de bandeja recibidas

Paso	Actor	Acción	Estado resultante
2	Médico (Estab. B)	Acepta la referencia: estado cambia a ACEPTADA. Desde este momento, el médico del Estab. B puede acceder a los datos del paciente conforme a la Regla 2 del Reporte Técnico v3	Acceso cross-establecimiento habilitado
3	Médico (Estab. B)	Atiende al paciente. Crea nuevo encuentro_clinico en Estab. B. Accede al expediente del paciente incluyendo notas del Estab. A (solo las de la especialidad referida)	Consulta de referencia activa
4	Médico (Estab. B)	Finaliza la atención: estado de referencia cambia a ATENDIDA. Registra los hallazgos y diagnóstico de atención	Referencia atendida

Sub-flujo C — Contrarreferencia

Paso	Actor	Acción	Estado resultante
1	Médico (Estab. B)	Emite contrarreferencia al Estab. A: diagnóstico definitivo, tratamiento instaurado, indicaciones para seguimiento	Documento de contrarreferencia generado
2	Sistema	Crea registro vinculado en referencias_medicas con tipo = CONTRAREFERENCIA. Notifica al médico del Estab. A	Ciclo de referencia completo
3	Médico (Estab. A)	Recibe la contrarreferencia en su bandeja. El acceso cross-establecimiento del Estab. B se revoca automáticamente (referencia estado = CERRADA)	Acceso restringido restaurado
4	Sistema	Registra CIERRE_REFERENCIA en auditoria_accesos. El expediente del paciente en Estab. A muestra el resumen de la referencia como parte del historial	Trazabilidad completa del SRC

Diagrama 6 — Flujo de Incidente de Seguridad

Este diagrama describe el ciclo de vida completo de un incidente de seguridad en MedIA, desde su detección automática o manual hasta su cierre formal. Implementa los requisitos forenses 1, 5 y 7 del documento de Cómputo Forense y gestiona la tabla incidentes_seguridad del modelo de datos.

Fase 1 — Detección

Un incidente de seguridad puede detectarse por cuatro vías:

- Alerta automática de Azure Monitor: CPU > 80%, intentos de login fallidos > 20 en 5 min, HTTP 5xx > 10
- Trigger de PostgreSQL: el trigger tr_audit_no_changes detecta intento de modificar auditoria_accesos y genera alerta de nivel CRÍTICO
- Detección manual por AUDITOR_SEGURIDAD: al revisar la bitácora, identifica patrones anómalos
- Reporte externo: usuario reporta comportamiento inusual al Administrador

Fase 2 — Clasificación

Paso	Actor	Acción	Estado resultante
1	AUDITOR / SUPERADMIN	Recibe alerta. Accede al módulo Auditoría e inicia un nuevo incidente seleccionando 'Registrar incidente'	Formulario de incidente abierto
2	AUDITOR / SUPERADMIN	Clasifica el incidente por tipo: ACCESO_NO_AUTORIZADO, MODIFICACIÓN_DATO_CLINICO, INTENTO_SQL_INJECTION, BRUTE_FORCE, FUGA_INFORMACION, u OTRO	Tipo de incidente asignado
3	AUDITOR / SUPERADMIN	Asigna nivel de severidad: CRITICO (riesgo inmediato a datos clínicos), ALTO (posible brecha), MEDIO (comportamiento anómalo), BAJO (observación preventiva)	Severidad asignada
4	Sistema	Crea registro en incidentes_seguridad con estado = ABIERTO, fecha_deteccion = NOW(), descripcion_inicial. Registra en auditoria_accesos tipo_evento = INCIDENTE_CREADO	Incidente registrado con timestamp UTC inmutable

Fase 3 — Contención

Paso	Actor	Acción	Estado resultante
1	SUPERADMIN	Si el incidente es CRITICO o ALTO: invalida la sesión del usuario sospechoso desde el módulo Seguridad (sesiones activas). Crea registro en sesiones_invalidas	Sesión del actor invalidada inmediatamente
2	SUPERADMIN	Si se identifica un patrón de IP maliciosa: configura regla en Azure Front Door para bloquear el rango de IP	Contención a nivel de infraestructura
3	AUDITOR / SUPERADMIN	Documenta las acciones de contención en el campo acciones_contencion del incidente. Cambia estado a EN_INVESTIGACION	Evidencia de contención registrada
4	Sistema	Todas las acciones de contención generan registros adicionales en auditoria_accesos con nivel_severidad correspondiente. La cadena de custodia digital queda íntegra	Trazabilidad forense garantizada — Req. Forense 3

Fase 4 — Erradicación

Paso	Actor	Acción	Estado resultante
1	AUDITOR / SUPERADMIN	Identifica la causa raíz del incidente revisando la bitácora. El campo modulo_funcion en auditoria_accesos permite identificar qué endpoint o función fue invocada	Causa raíz identificada — Req. Forense 3
2	Equipo técnico	Si la erradicación requiere cambio de código: se abre issue en GitHub, se desarrolla el fix, se despliega mediante CI/CD de GitHub Actions	Vulnerabilidad eliminada del código
3	SUPERADMIN	Documenta la causa raíz y las acciones de erradicación en el campo causa_raiz del incidente. Cambia estado a ERRADICADO	Documentación técnica del incidente completa

Fase 5 — Cierre Formal

Paso	Actor	Acción	Estado resultante
1	SUPERADMIN	Verifica que el sistema opera con normalidad post-erradicación. Revisa que no haya alertas activas en Azure Monitor	Verificación post-incidente
2	SUPERADMIN	Cierra el incidente: estado = CERRADO, fecha_cierre = NOW(), resolucion_descripcion con el resumen ejecutivo del incidente	Incidente cerrado con timestamp inmutable

Paso	Actor	Acción	Estado resultante
3	Sistema	El incidente cerrado queda visible en la bitácora de incidentes con todos sus estados históricos. No puede eliminarse (borrado lógico: eliminado_en permanece NULL, no hay soft delete en incidentes)	Registro permanente del incidente — Req. Forense 6
4	AUDITOR	Genera reporte PDF del incidente para documentación institucional. El reporte incluye: timeline completo, actores involucrados, acciones tomadas, causa raíz y recomendaciones	Entregable forense documentado

NOTA FORENSE CRÍTICA

Conforme al Requisito Forense 6 (No borrar ni sobrescribir evidencia), ningún registro de incidente, ni ninguna entrada de auditoria_accesos, puede eliminarse física ni lógicamente del sistema. El trigger tr_audit_no_changes lo garantiza a nivel de base de datos. Cualquier intento de DELETE o UPDATE en estas tablas genera un error 403 y registra a su vez un evento INTENTO_MANIPULACION_AUDITORIA con severidad CRITICO.